

Security and Permissions Design 5-4

(1) المصادقة

التنفيذ	العنصر
Laravel Sanctum — Personal Access Tokens	الآلية
localStorage + Authorization: Bearer	التخزين
حذف التوكن الحالي	Logout
ليست JWT؛ الجدول personal_access_tokens	ملاحظة

(2) الأدوار

الدور	الاسم	الصلاحيات
Student	student	مقترحات، مشاريع، مهام، تقدّم
Supervisor	supervisor	مراجعة مقترحات، إشراف، توافر، مناقشات
University Admin	admin	مستخدمون، XML، مسارات، جدولة، لجان
Super Admin	super_admin	إدارة الجامعات والمنصة

Middleware (3)

- auth:sanctum — توكن صالح.
- EnsureUserHasUniversity — ارتباط بجامعة (إلا super_admin).
- user.status — active أو graduated فقط.
- ...:role — تقييد حسب الدور.
- TenantScope — عزل بيانات الجامعة.

4) التسجيل والاعتماد

1. استيراد XML للمستخدمين المصرّح لهم.
2. تطابق XML → active، وإلا pending.
3. المدير يوافق أو يرفض.
4. pending/rejected لا يدخلان الـ API المحمي.

5) Multi-Tenancy

السجلات تحمل university_id. BelongsToUniversity + TenantScope university_id. يمنعان رؤية بيانات جامعة أخرى.
super_admin يتجاوز النطاق لإدارة المنصة.